

The Cult of Robust

What IT Security Professionals Can Learn From The Horizon IT Scandal

By David Bank, CISSP

© 2025-2026 David Bank

Without limiting the exclusive rights of any author, contributor and/or authorized publisher of this creative work, the use of this publication to train artificial intelligence, of a "generative" type, or of any other type known or unknown at the time of publication, is expressly prohibited. The copyright holder also exercises their rights under Article 4(3) of the Digital Single Market Directive 2019/790 and expressly reserves this publication from the text and data mining exceptions.

The Horizon IT scandal¹ is a long-running (and, as of this writing, still-unfolding) debacle that has shaken the British government, and its judiciary. In January of 2024, then-Prime Minister Rishi Sunak called it an “appalling miscarriage of justice”². This paper will not recount minute details of the catastrophic failures in governance and management; there are ample online resources³ for those wanting the blow-by-blow.

For the purposes of this paper, a concise summation is that for more than a decade, data from a *deeply* flawed accounting/electronic point-of-sale system (known as “Horizon”, designed and operated by the UK arm of Fujitsu) was portrayed as rock-solid evidence that employees (known as “Sub-PostMasters”, or “SPMs”) were stealing money from the Government-owned Post Office corporation (known as “POL”⁴).

The unreliable data was used in criminal prosecutions and civil actions that put hundreds of innocent people in prison, destroyed livelihoods, wrecked families and, in some cases, ended lives. The entire time, POL (and Fujitsu) insisted the accounting system was incapable of error, actively suppressed any attempts to uncover information to the contrary, and obstructed justice by deliberately concealing evidence from discovery at trials or during appeals⁵.

One could be forgiven for thinking the only real problem was jurisprudence. By any measure, POL enjoyed astonishing levels of credulity from the courts. POL’s legal counsel, both internal and external, careened from malice to incompetence and back again, deliberately hiding exculpatory information, often by fraudulent legal privilege claims⁶. Unsustainable charges were filed in sadistic attempts to gain guilty pleas. Those pleas were leveraged by civil suits to “recover” money (that was never actually missing), as POL’s management actively sought to bankrupt the victims. And judges of the British court system enabled it all⁷.

Nevertheless, it is clear that the underlying problems went far beyond the legal profession. Without question, IT breakdowns formed a core part of the scandal. Arguably, however, it was IT security issues (specifically, the truth about unaudited remote access to accounting data) that lit the fuse of the powder keg and set off the explosion.

I propose there are lessons IT security professionals can draw from the fiasco, and I present some in this paper. These are primarily based on my review of materials provided through the Post Office Horizon IT Inquiry⁸, including scores of hours of public hearing videos, many hundreds of pages of transcripts and witness statements, and mountains of other evidence gathered by the Inquiry. I encourage anyone reading this paper to devote time to examining the materials provided on the website.

1 Varies called the “British Post Office scandal”, “UK Post Office scandal” and the “Horizon IT scandal”. The terms can be considered interchangeable.

2 <https://www.bbc.com/news/uk-politics-67905688> (BBC, retrieved 2025-10-24)

3 A good starting point is https://en.wikipedia.org/wiki/British_Post_Office_scandal (Wikipedia, retrieved 2025-10-24)

4 Post Office, Limited; see https://en.wikipedia.org/wiki/Post_Office_Limited (Wikipedia, retrieved 2025-10-24)

5 <https://www.bbc.com/news/articles/cvgeq7z4ylyo>

6 See Mr. Justice Fraser’s Horizon Issues judgement at paragraphs [457] and [458]

7 “The harm that judges do – misunderstanding computer evidence” by Paul Marshall https://www.bailii.org/uk/other/journals/DEESLR/17_5172.pdf (Digital Evidence and Electronic Signature Law Review, retrieved 2026-05-06)

8 <https://www.postofficehorizoninquiry.org.uk> (Post Office Horizon Inquiry, retrieved 2023-10-24)

Lesson #1: No, Management Does Not Understand

As a security professional, at some point, one is going to have to present one's findings and solutions to management⁹. In our jobs, we gather information, apply both our body of experience and knowledge of standards and good practices, and finally adduce courses of action.

One important truth emerged from the hours of testimony by (and about) the people in POL's management structure. Over the course of years, multiple levels of that management were told the Horizon system had significant data integrity issues that could (indeed, were *likely* to) lead to accounting discrepancies – basically, *illusory* cash shortfalls.

These repeated warnings were ignored. At all levels, the people in leadership roles variously claimed the ramifications were not understood, the warnings were incomprehensible, and/or that they somehow, inexplicably, overlooked the information. Clear statements that would have raised frantic alarms in any competent IT professional were ignored, minimized, discounted and dismissed.

The lesson that emerged is re-stated simply: **Management does not understand.**

Obviously, there's no way to "make" them understand; indeed, POL's executive management clearly didn't *want* to understand. Nevertheless, there are things we, as security professionals, can do.

First and foremost, avoid assuming that IT security domain knowledge exists in any management audience. A particular danger is vocabulary; terms of art common to the IT security field may convey different meanings to others who have not pursued the same course of study. For example, how the term "risk" is understood by a CFO or member of the Board of Directors is probably different than how IT security professionals define the word.

Next, findings must be clearly stated, and risks defined in unambiguous terms. **It is not enough to provide the dots; connect them, explicitly.** Avoid weasel-words¹⁰, and utilize concise descriptions that make it difficult to rationalize ignoring risks. If needed, reference very public IT failures (such as Horizon), complete with expensive consequences, as pointed object lessons.

Finally, challenge complacency, unmask fallacies, and dispute casual dismissals. Where it proves impossible to overcome a lack of (or lack of desire for) understanding, consider the alternatives within the organization. Are the warnings reaching the right people?

Lesson #2: Perry Mason Is Real

If you take the time to view the videos of the oral testimony given by POL employees/contractors, a warning. It is painful to watch a seemingly endless succession of complete morons, punctuated every so often by a depressingly smug lawyer from one of the dizzying array of external law firms retained by POL, take the stand, swear to tell the truth, and then recite a litany of bald-faced lies.¹¹

9 I define "management" as people who "direct" rather than those who "do". This is not a dig at managers. It's simply the typical situation in most business settings.

10 https://en.wikipedia.org/wiki/Weasel_word#Forms

11 I reference the testimony of a number of people, including (to name just a few, and in no particular order) Elaine Cottam, John Roberts, Keith Todd, Mike Young, Simon Oldnall, Angela van Bogerd and Andy Dunks; plus, pretty much **any** POL employee identified as an "investigator" or "auditor" (the latter merely counted stock and cash and only required a skill-set common to most 10-year-old schoolchildren; the former were apparently incapable of conducting an "investigation" recognizable as such, and instead would get a Horizon print-out, then accuse the SPM of theft, and bully them with demands to know where the money was, all the while lying by telling the SPM that absolutely no one else had any problems).

There **is** an occasional bit of comic relief. It happens when one of the witless POL witnesses states they have no knowledge of a specific topic, discussion, meeting or message; and the counsel for the Inquiry directs them to a memo, set of meeting minutes, E-mail, call log or other document that shows they were included in the discussion, or were at the meeting, or had been sent documents they professed, moments before, were unknown to them. In some cases, POL employees claimed to know nothing about a critical matter, only to be shown an E-mail or other document, *that the POL employee authored*, and in which they *specifically addressed the topic*. A Perry Mason moment¹² is almost guaranteed once *per* POL witness (sometimes, more often).

What is the lesson? **The truth will out.**

As IT security experts, we ostensibly know about e-discovery. However, absent first-hand knowledge, I suspect that, even in our field, few appreciate the length and breadth of what will inevitably come to light. In the world of e-discovery, Enron-style “shredding parties”¹³ are exercises in futility.¹⁴

In a worst-case scenario, we may find ourselves in a position where we are faced with a choice between a full and frank disclosure of our personal knowledge that might adversely affect our employer/client *versus* the temptation to craft our disclosure in such a way to “cover” for an employer/client.

Choosing the latter is practically guaranteed to be the worst option. In the IT security field, we live and breathe by our professional reputation. It is foolish to assume that “covering” for an employer/client will meet with success. Moreover, doing so opens the door to being caught, and damaging the one thing that we cannot restore from backup: our reputation.

Lesson #3: The Design Is Not The System

In the press and in legal actions, the technical defense of Horizon frequently centered around extolling the virtues of its design. Its security was (laughably) described as “military grade”; impressive words were used in complicated explanations of how it ensured data integrity (which, in reality, was not very well). POL frequently cited meaningless statistics as part of deflecting questions, and couched denials in terms of expected outcomes.

Almost without fail, employees at every level of the Post Office, from front-line workers to the chairperson of the board, called it “robust”.

Robust. The word became the calling card of the Post Office cult, wherein members accepted the perfection of Horizon without question. For the cultist, it was heresy for anyone to suggest that Horizon could possibly be fallible. An SPM who claimed Horizon was the cause of shortfalls was lying; they had “lifestyle issues”, they were thieves, or incompetent. If a judge ruled against POL in a Horizon case, that judge was clearly biased and needed to be recused¹⁵. When independent auditors, who were *selected by POL*, began to question Horizon’s real-world behavior, they were described as having “gone native”, and action launched to shut down their investigations. The board of directors castigated the chief counsel for failing to insure that those *independent* auditors would return the results POL wanted.

12 https://en.wikipedia.org/wiki/Perry_Mason_moment

13 https://en.wikipedia.org/wiki/Enron_scandal#Financial_audit

14 The second appearance of Graham Ward, on Day 154 of the hearings, is an excellent example of this phenomenon.

15 <https://www.lawgazette.co.uk/commentary-and-opinion/post-office-plays-hardball-with-ironman-judge/5069964.article>

Instead of competent and thorough examinations of how Horizon functioned in practice, the cultists preferred so-called “desk audits”¹⁶ as the beginning and the end of their “investigations”.

We must, as security professionals, acknowledge a basic truth: **Desk audits of security are worthless.**

A desk audit is the IT security equivalent of spilling warm tea in one’s lap while wearing dark clothes; it feels good, but no one else notices. It fails to reveal how actual implementation differs from the plan, the effect of software changes since original implementation, and it doesn’t expose where something that was supposed to occur did not happen in reality.

Do not make the mistake of betting your career on what a pile of paper is saying. Go look for yourself.

Lesson #4: Corporations Are, At Best, Amoral

Towards the end of the ITV docudrama *Mr. Bates vs. The Post Office*¹⁷, some of the characters discuss the outcome. One asks if the people in the Post Office were incompetent, or evil. The reply? At a certain point, there’s really no difference. Deliberate intent is not required to cause great harm; garden-variety bungling can potentially yield the same results. As the scandal has shown, POL was built on bungling¹⁸.

However, simply “getting it wrong” cannot begin to describe what happened. The executive leadership of POL consciously and deliberately went from simply amoral to manifestly malevolent behavior¹⁹. Richard Moorhead, a British lawyer, has a blog concerning the implications of the Horizon scandal for UK legal professionals. In one particular post²⁰, he observes:

[A] pathological organisation [like the Post Office is] filled with chains of communication but devoid of functioning chains of responsibility. Everyone is involved, but no one is actually making the decisions, particularly the flawed ones; or is making decisions on information flawed in ways they cannot be held responsible for.

As security professionals, we must be attuned to the reputational danger of involvement with a company that is, as he aptly identifies, pathological. Aside from perhaps lawyers, how many people who were involved in the scandals of, say, Enron (or Boeing, or Lehman Brothers, or...) actually benefited – in the professional sense – from the events? If we find ourselves in an organization that is sliding into darkness and malevolence, as POL did; and, further, is resistant to reasonable attempts to change course; then we must consider leaving that organization.

Lesson #5: De-Skilling Kills

Starting around the time that Horizon was introduced, the Post Office underwent multiple bouts of “transformation”, a typical British-polite term for “dramatic layoffs”. As happens any time a company tries to cut its way to profitability, POL was systematically de-skilled, with legions of capable

16 https://en.wikipedia.org/wiki/Desk_audit

17 https://en.wikipedia.org/wiki/Mr_Bates_vs_The_Post_Office

18 <https://www.postofficescandal.uk/post/more-singhd-against-than-singh-ing/>

19 <https://www.postofficehorizoninquiry.org.uk/sites/default/files/2023-03/Paul%20Marshall%20submission%20re%20Bankruptcy.pdf>; paragraphs 9-28, 36-39, and 42-58 (www.postofficehorizoninquiry.org.uk, retrieved 2026-04-10)

20 <https://richardmoorhead.substack.com/p/this-is-normal-iv-divisions-of-irresponsibility>

employees departing (voluntarily or otherwise) in the earlier years. The result was an organization not only lacking coherent understanding of (let alone competence in) the technology underpinning core business functions, but one that was likewise bereft of critical institutional knowledge and memory (to say nothing of the apparent loss of anything resembling a conscience or sense of ethics).²¹

By its own hand, the Post Office became wholly dependent on Fujitsu for IT expertise. It was therefore incapable of comprehending how Horizon worked (or failed) in practice, or realizing when vendors were lying (or, for that matter, overcharging). Understandably, through the scandal and the Inquiry, POL is not being allowed to hide behind its self-inflicted ineptitude; just as voluntarily-intoxicated drivers are held responsible for accidents on the road, so too must the Post Office accept liability for the situations its structural failures created.

The lesson for the security professional is to recognize the red flags thrown off by the de-skilled organization (or one that begins to de-skill itself). Once it has started, it's generally impossible to stop, so the best course for the competent is usually to exit sooner rather than later. Employment should not become a professional suicide pact.

Final Thoughts

IT security professionals are like every other white-collar worker in that we serve the needs and interests of a business. That said, we differ in that we depend, more than most, on our reputation for integrity. Certain behaviors apropos a board room or C-suite would be destructive for the IT security professional. There are lines that we simply must not cross.

The British Post Office scandal highlights how it built itself on crossing lines²². Examining POL reveals a plethora of warning signs and red flags that help identify organizations that pose particular threats to us. Study the debacle and learn the lessons so you can avoid the danger in the future.

²¹ As an example, see the testimony of David Miller, given on October 28, 2022; specifically, the Core Participant questioning

²² <https://www.linkedin.com/pulse/knew-had-logs-said-nothing-stuart-gw-dmiaie/>